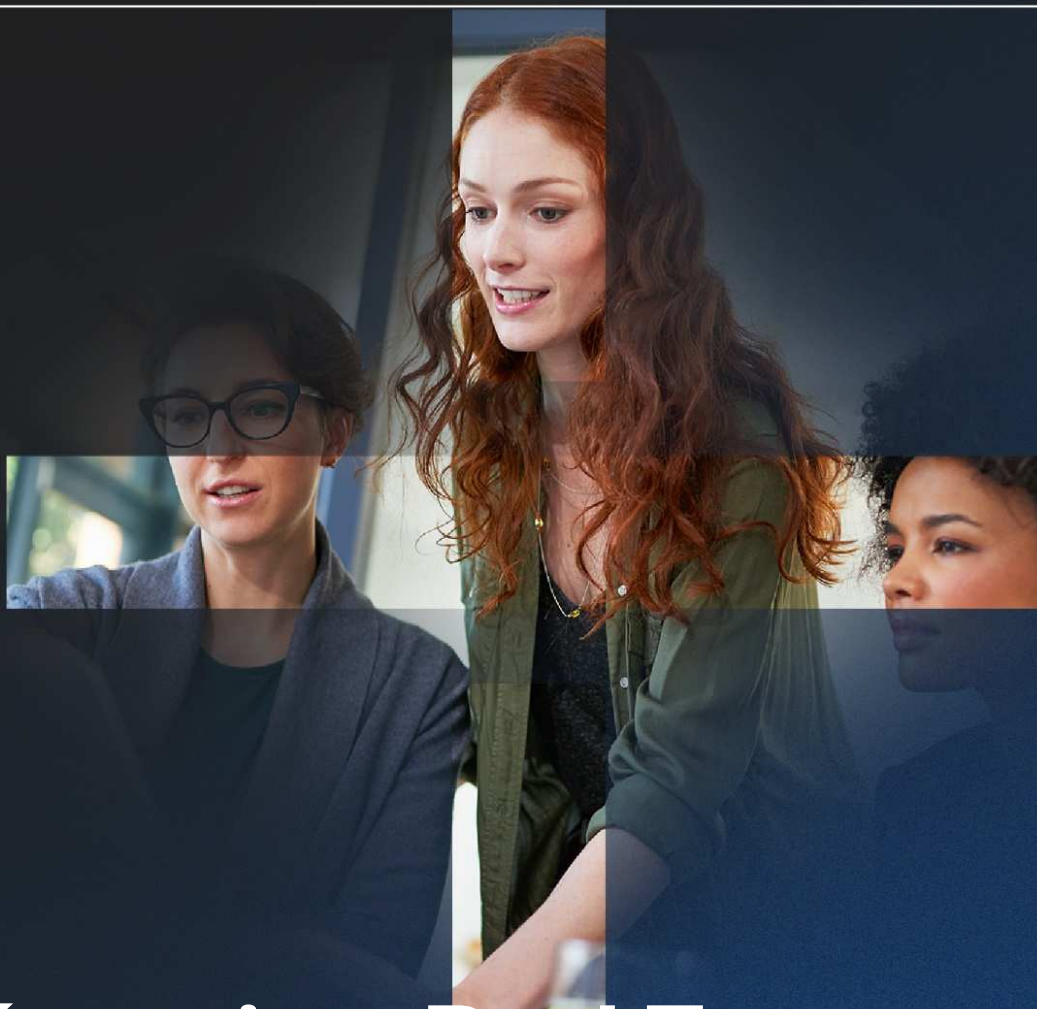




Détection Red Team

Méthodologie de réponse à incident

2025-10-31 | **IRM-20**

CERT aDvens - CSIRT

Advens - 38 rue des Jeuneurs - 75002 Paris

SOMMAIRE

Introduction 2

Étapes de traitement des incidents 2

1. Préparation 3

2. Identification 4

3. Confinement 5

4. Remédiation 6

5. Récupération 7

6. Capitalisation et apprentissage 8

INTRODUCTION

Cette méthodologie de réponse à incident est une feuille de route destinée aux analystes, pour détecter et investiguer sur des incidents de sécurité liés à des exercices Red Team au sein de l'entreprise.

→ La fiche IRM s'adresse aux personnes ou fonctions suivantes :

- Les membres de la Blue Team
- Les SOC (Centres de supervision de sécurité)
- Les RSSI et leurs adjoints
- Les équipes CERT (Computer Emergency Response Team)



Si vous suspectez un exercice de Red Team, appliquez la méthodologie IRM, consignez vos observations et informez immédiatement l'équipe de réponse à incident de votre entité, le CERT ou toute équipe bleue (blue team) concernée.

Références

- [IRM CERT-SG](#)
- [IRM CERT-aDvens](#)

Objectif de l'IRM

L'objectif de la méthodologie de réponse à incident pour la détection d'exercices Red Team (IRM20) est de fournir une approche structurée et systématique permettant d'identifier, gérer et traiter les incidents impliquant les actions d'une Red Team ou d'autres entités offensives de cybersécurité ciblant les systèmes d'information de l'organisation.

Par essence, cette méthodologie vise à renforcer les capacités globales de l'organisation en matière de détection, d'investigation et d'atténuation des cybermenaces potentielles menées par des acteurs malveillants sophistiqués.

ÉTAPES DE TRAITEMENT DES INCIDENTS

6 étapes sont définies pour gérer les incidents de sécurité :

1. **Préparation** : Se préparer à gérer l'incident,
2. **Identification** : Détecter l'incident,
3. **Confinement** : Limiter l'impact de l'incident,
4. **Remédiation** : Supprimer la menace,
5. **Récupération** : Revenir à un état normal,
6. **Capitalisation et apprentissage** : Élaborer et améliorer les processus.

Cette IRM fournit des informations détaillées pour chaque étape du processus de réponse à incident. Ces étapes sont issues du guide de gestion des incidents de sécurité informatique du [NIST](#).

Cette fiche est issue du travail collaboratif avec le **CERT-SG** de modification et de mise à jour de leurs fiches de méthodologie de réponse à incident.

1. PRÉPARATION

Objectifs : Établir des contacts, définir des procédures et recueillir des informations pour gagner du temps lors d'un incident impliquant une Red Team.

- Mettre en place des canaux de communication pour informer les parties prenantes des détections d'activités de la Red Team ; garder à l'esprit la possible appartenance commune de certains membres de la White et de la Blue Team afin d'éviter les conflits d'intérêts,
- Identifier les membres de la White Team et définir des points de contact avec eux,
- Utiliser des systèmes de détection d'intrusion réseau et sur les hôtes. S'assurer qu'ils soient correctement configurés pour surveiller efficacement le trafic réseau et les systèmes d'extrémité à la recherche d'activités malveillantes. Vérifier qu'une journalisation et qu'une supervision sécurisée des activités système et réseau sont mis en place et fonctionnels, que les événements sont correctement journalisés et transmis au SIEM, et qu'il existe des règles pertinentes et testées pour générer des alertes,
- Configurer et tester régulièrement les outils SIEM pour collecter, analyser et réagir aux événements de sécurité. Ces outils peuvent être réglés pour détecter des signes d'activités de la Red Team, tels que les échecs de connexion, les changements de configuration et les tentatives de reconnaissance du réseau,
- S'assurer que les solutions de protection des postes et serveurs intègrent des mécanismes de détection efficaces contre les logiciels malveillants, reposant sur des analyses statiques et dynamiques. Garantir la couverture de l'ensemble des environnements : postes utilisateurs, serveurs, systèmes d'exploitation variés, appareils mobiles et BYOD le cas échéant.
- Définir des points de contact spécifiques 24 heures sur 24 et 7 jours sur 7, ainsi que les personnes qui interviendront en cas d'urgence,
- Établir une coordination opérationnelle entre les Blue Team existantes (SOC, CERT, autres entités en matière de sécurité) et organiser régulièrement des exercices de réponse aux incidents en intégrant les membres des différentes Blue Team,
- Réviser et évaluer régulièrement les contrôles de sécurité, les politiques et les procédures de l'organisation,
- Mettre en œuvre une procédure de type "Bouton Rouge" pour arrêter ou suspendre temporairement toutes les activités de la Red Team en cas de nécessité opérationnelle (incident réel concomitant, impact en production, etc.),
- Préparer des stratégies de communication internes et externes, et les outils à utiliser lors d'un exercice de Red Team, en incluant des canaux de communication alternatifs afin d'éviter toutes fuites d'informations entre les membres de la Blue Team et de la Red Team,
- Donner aux membres de la Blue Team une compréhension actualisée des cybermenaces, du rôle de la Red Team et des méthodes qu'elle peut utiliser. Cela inclut les schémas d'attaques précédentes, les TTP couramment employées et les IOC déjà observés. Fournir, si possible, les rapports d'exercices précédents de Red Team ainsi que les retours d'expérience associés,
- Préparer la documentation officielle de la mission, y compris tous les documents nécessaires tels que les règles d'engagement, les objectifs de la mission, la description détaillée du scénario, la carte "Sortie de prison" et tout document supplémentaire attestant du soutien des principaux acteurs clés, tels que le RSSI, DSI, etc.



Être prêt à informer les acteurs de niveau C (*C-level (NdT: dirigeants d'entreprises et cadres supérieurs)*) si nécessaire lors d'un incident de Red Team.

2. IDENTIFICATION

Objectifs : Détecter l'activité de la Red Team, déterminer son ampleur et impliquer les acteurs concernés.

Détection

- Surveiller les signes de compromission et les comportements inhabituels dans votre environnement (mouvements latéraux, mécanismes de persistance, etc.),
- Investiguer sur les alertes de sécurité et analyser les journaux à la recherche d'indicateurs d'une éventuelle activité de la Red Team,
- Qualifier les incidents potentiels pour déterminer s'ils peuvent faire partie d'un exercice de la Red Team,
- Évaluer l'ampleur et les impacts potentiels de l'activité de la Red Team. En cas d'incertitude, consulter la White Team afin d'éviter toute confusion avec une attaque réelle et une mauvaise gestion d'incident,
- Une fois l'incident validé, déterminer quels systèmes sont affectés, quelles données ont pu être exposées ou exfiltrées et quel impact global cet incident peut avoir sur les activités de l'entreprise. Pour fournir des réponses adéquates, il peut être nécessaire d'anticiper les objectifs finaux recherchés par la Red Team,
- Impliquer l'ensemble des acteurs identifiés précédemment, et sans s'y limiter, les équipes Blue Team, métiers, support d'infrastructure et le personnel en charge de la sécurité de l'information. Évaluer l'impact potentiel à partir des informations disponibles sur l'incident et les retours des équipes métiers et techniques,
- Évaluer les scénarios de remédiation envisageables tels que le blocage des interconnexions, le renforcement de la surveillance, en s'appuyant sur l'analyse de risques par rapport aux impacts potentiels sur la production. Agir avec une discrétion maximale pour ne pas révéler aux membres de la Red Team qu'ils ont été identifiés,
- Si la validation et l'évaluation confirment qu'il s'agit d'un exercice de la Red Team, escalader l'incident vers la direction en fournissant immédiatement et avec précision tous les détails nécessaires,
- Les coordinateurs de la White Team doivent établir des canaux de communication avec les acteurs concernées pour partager en permanence les informations sur l'exercice en cours. Si la nature de l'incident l'exige, mettre en place des canaux de communication alternatifs et dédiés (hors du réseau de l'entreprise) pour l'échange d'informations et de données pendant l'exercice.

Envisager de consulter d'autres IRM qui pourraient s'appliquer à la mission présumée de la Red Team :

- [IRM-02 Intrusion sur Windows](#)
- [IRM-03 Intrusion sur Linux](#)
- [IRM-07 Détection de malware sur Windows](#)
- [IRM-10 Ingénierie sociale](#)
- [IRM-11 Fuite d'informations](#)
- [IRM-14 Scam](#)
- [IRM-16 Phishing](#)
- [IRM-17 Ransomware](#)
- [IRM-18 Compromis large périmètre](#)

3. CONFINEMENT

Objectifs : Empêcher la progression de l'attaque et limiter sa portée.

- Isoler toutes les machines compromises ou les systèmes affectés pour empêcher toute nouvelle intrusion ou propagation de l'attaque,
- Mettre en place des contrôles d'accès et une segmentation du réseau afin de limiter la portée de l'attaque,
- Organiser des réunions régulières avec le prestataire et les acteurs concernés,
- Se coordonner avec les parties prenantes métiers impactées pour appliquer des mesures de confinement, telles que l'isolement des systèmes compromis, le blocage des IoC malveillants ou le changement des identifiants - en conformité avec les exigences de sécurité métier,
- Simuler les contre-mesures les plus risquées ou impactantes pour éviter des pertes de production.

Si un trafic est critique pour l'entreprise et ne peut être déconnecté, autoriser le après avoir mis en place des contrôles de sécurité supplémentaires afin de détecter et d'empêcher toute latéralisation.

Si applicable aux "IOC de la Red Team" (vérifier deux fois avant de l'appliquer, car cela peut déclencher des réactions indésirables des membres de la Red Team) :

- Bloquer le trafic vers les C2 identifiés,
- Bloquer les accès vers/depuis toute infrastructure de la Red Team,
- Désactiver ou restreindre les comptes compromis par les attaquants,
- Envoyer des échantillons non détectés à votre fournisseur de solution de sécurité des postes, aux éditeurs d'antivirus et aux plateformes de bac à sable,
- Envoyer les URL, les noms de domaine et les adresses IP malveillantes non catégorisés à vos prestataires de sécurité.

Il peut être pertinent de simuler des contre-mesures risquées ou potentiellement impactantes, afin d'éviter les effets indésirables de l'exercice sur la production.

4. REMÉDIATION

Objectifs : Supprimer les accès de la RedTeam et sécuriser vos systèmes.

- Examiner en détail les résultats des phases précédentes. S'assurer que les points d'accès initiaux de la Red Team, leurs implantations dans les systèmes, les mouvements latéraux et les mécanismes de persistance ont été correctement identifiés,
- S'assurer que les vulnérabilités exploitées par la Red Team et les autres méthodes d'attaque sont bien comprises,
- Une fois que toutes les tactiques, les méthodes et les vulnérabilités ont été identifiées, les prioriser en fonction de leur impact potentiel sur la sécurité. Commencer par appliquer les correctifs des vulnérabilités les plus risquées, puis continuer aux moins critiques,
- Sur la base des constatations, renforcer les configurations du système afin d'empêcher de futures exploitations. Il peut s'agir de mesures telles que le renforcement des paramètres de sécurité, la limitation des privilèges des utilisateurs, la désactivation des services inutiles et l'affinement des règles du pare-feu. Cela s'applique également à la phase des enseignements tirés,
- **Localiser et supprimer les mécanismes de persistance, les portes dérobées ou les webshells que la Red Team aurait pu laisser sur les systèmes au cours de l'exercice.** Mener une investigation approfondie afin de s'assurer qu'aucune vulnérabilité résiduelle ou porte dérobée ne subsiste,
- Effectuer des tests de validation afin de confirmer que les actions de remédiation ont permis de sécuriser les systèmes compromis. Vérifier que la Red Team ou toute autre entité offensive ne peut exploiter les vulnérabilités précédemment identifiées,
- Documenter rigoureusement toutes les étapes de la remédiation, leurs résultats et les difficultés rencontrées au cours du processus. Transmettre aux acteurs concernées les résumés des mesures correctives et les solutions de contournement, y compris les descriptions de la manière dont ces vulnérabilités ont été exploitées par la Red Team. Cette étape s'applique également à la phase des enseignements tirés.

Recommandations supplémentaires de précaution : en cas de signes de latéralisation, veuillez vous référer à l'IRM 18 - Compromission Large Périmètre.

5. RÉCUPÉRATION

Objectif : Revenir à un fonctionnement normal.

Toutes les étapes suivantes doivent être réalisées pas à pas et sous le contrôle technique des Blue, Red, White et Purple Team.

- Confirmer l'efficacité des stratégies de remédiation utilisées. Vérifier que les vulnérabilités ont été corrigées, que les configurations des systèmes ont été renforcées et que les mécanismes de persistance ont été supprimés. Les systèmes doivent être sécurisés avant la reprise des activités normales,
- Rétablir les systèmes et les services dans leur état de fonctionnement normal. Dans certains cas, cela peut impliquer des étapes supplémentaires telles que la reconstruction / réinstallation des systèmes, la restauration des données à partir des sauvegardes ou la migration vers de nouvelles plateformes, en fonction de l'étendue de l'attaque de la Red Team,
- Une fois les systèmes restaurés, effectuer des tests fonctionnels et de sécurité approfondis afin de s'assurer que les systèmes fonctionnent de manière optimale et qu'ils ne sont plus vulnérables à des attaques similaires. Travailler avec les responsables métiers concernés pour restaurer tous les services ou les systèmes affectés, en veillant à ce qu'ils soient sécurisés et exempts de vulnérabilités,
- Surveiller les performances des systèmes afin de détecter toute anomalie ou tout problème de sécurité potentiel dans le cadre de la phase de récupération. S'assurer que les systèmes fonctionnent normalement et qu'ils ont conservé leurs niveaux de performance antérieurs à l'exercice de la Red Team,
- Déclarer la fin de la phase de récupération uniquement lorsqu'il est confirmé que tous les systèmes sont de nouveau opérationnels, sécurisés et stables. Toute anomalie ou incidence liée à l'exercice de la Red Team doit avoir été traitée.

Vérifier les trois points suivants : que les vulnérabilités ont été corrigées, que les configurations du système ont été durcies et que les mécanismes de persistance ont été supprimés. Le système doit être sécurisé avant toute reprise d'activité normale.

6. CAPITALISATION ET APPRENTISSAGE

Objectifs : Documenter les détections de l'exercice de la Red Team, examiner les enseignements tirés et améliorer les plans de défense.

Rapport

Un rapport de mission de la Red Team doit être rédigé et mis à la disposition de toutes les parties prenantes impliquées. Différents formats du rapport peuvent être nécessaires pour le présenter à différents publics, à différents niveaux stratégiques, opérationnels et tactiques.

Les thèmes suivants doivent être abordés :

- Cause initiale de la compromission,
- Actions et chronologie de chaque événement important,
- Ce qui a bien fonctionné,
- Ce qui n'a pas fonctionné,
- Tactiques, techniques et procédures (TTPs),
- Indicateurs de compromission (IoC).

Capitalisation

- Documenter les résultats de l'exercice, y compris les méthodes d'attaque, les vulnérabilités et l'impact - ces connaissances peuvent être utiles lors de futures missions de réponse à incidents,
- Évaluer l'efficacité des mécanismes de détection et de réponse,
- Identifier les axes d'amélioration et ajuster des changements dans les processus et dispositif de défenses,
- Partager les connaissances acquises lors de l'exercice avec les acteurs concernés,
- Organiser une réunion de débriefing avec toutes les parties impliquées. La Red Team doit y présenter sa méthodologie, ses tactiques, ses techniques et ses procédures, et expliquer comment elle a exploité les vulnérabilités du système,
- Effectuer une analyse détaillée de l'ensemble des opérations de réponse aux incidents, de la détection à la récupération. Identifier ce qui a bien fonctionné, ce qui n'a pas fonctionné et les opportunités d'amélioration,
- Documenter les enseignements tirés de l'exercice, en détaillant les difficultés rencontrées et leurs solutions. Dresser une liste des éléments nécessitant des mesures correctives supplémentaires, en précisant qui devrait être responsable de la mise en œuvre de ces changements,
- Sur la base des enseignements tirés, élaborer un plan d'action complet pour combler les lacunes identifiées. Prioriser les activités en fonction de leur importance et de leur urgence afin de vous assurer que les risques les plus élevés sont traités rapidement ("quick wins"),
- Désigner une personne chargée de suivre l'avancement de ces mises en œuvre. Cette mission pourrait être confiée à la Purple Team,
- Communiquer les résultats et les enseignements tirés à un plus large éventail d'acteurs. Cela pourrait s'étendre à l'ensemble de l'organisation pour améliorer la sensibilisation et les bons comportements en matière de sécurité,
- Prévoir un audit de suivi à moyen ou long terme pour vérifier la mise en œuvre des éléments du plan d'action découlant des conclusions de la mission de l'équipe rouge.

Un exercice de Red Team peut être considéré comme une phase préalable à un projet d'amélioration continue de type Purple Team.